

ARTICLE 2 OF 5 • NS-CMMF v1.0 MARKET INTRODUCTION SERIES

From Framework Proliferation to Unified Control Intelligence

How NS-CMMF v1.0 Consolidates 32 Frameworks and Regulations Into a Single, Operationally Coherent Control System

Published by Nucleus Systems • NS-CMMF v1.0 Market Introduction • Article 2 of 5 • 2026

The Nucleus Systems Cybersecurity Maturity Management Framework Version 1 (NS-CMMF v1.0) is the most comprehensive, consultable, and regulatory-aligned cybersecurity maturity framework available for mid-market and enterprise organizations operating across multiple jurisdictions. It reflects a fundamental modernization of traditional controls—re-engineered from legacy, static models to align with today's dynamic technologies, cloud-first architectures, and AI-driven operating environments. With 270 fully re-engineered and modernized controls, a 5-axis scoring model, and mapping to 32 frameworks and regulations, it replaces fragmented compliance checklists and opaque maturity ratings with a single, evidence-based instrument for measurement and continuous improvement.

A checklist asks, "Have you done this thing?" A framework asks: "How well are you doing this thing?"

The Framework Proliferation Crisis

There has never been more regulatory and framework guidance available to cybersecurity professionals, and there has never been less clarity about how to operationalize it all. In 2026, a mid-market organization with global operations might reasonably be expected to align with NIST CSF 2.0, ISO/IEC 27001:2022, CIS Controls v8, GDPR, NIS2, DORA, EU AI Act, PCI DSS v4.0.1, HIPAA, SOX, the Cyber Resilience Act, and IEC 62443. Each of these frameworks is valuable in its own right. Collectively, they create an operationally unmanageable burden that no organization with finite compliance resources can address coherently.

The consequences of this fragmentation are predictable and well-documented:

- Duplicated evidence collection: the same SIEM log retention evidence is collected separately for PCI DSS Req. 10, DORA Art. 17, SOX audit requirements, HIPAA §164.312(b), and NIS2 Art. 21—generating five separate evidence packages from a single operational control.
- Audit fatigue: security and IT teams spend disproportionate time preparing for audits and certifications rather than improving operational security. The average enterprise manages between 4 and 8 separate assurance programs annually.
- Coverage gaps: controls that span multiple frameworks but belong to no single framework's primary domain are routinely missed. The intersection of AI security and GDPR data processing obligations is a classic example—covered partially by both, comprehensively by neither.
- Regulatory exposure: organizations confidently pass ISO 27001 audits while remaining materially non-compliant with DORA or NIS2 obligations that were not in scope for the certification program.

The fundamental problem with managing multiple frameworks in parallel is not the complexity of any individual framework; it is the inability to see where they overlap, where they conflict, and where they leave gaps. NS-CMMF v1.0 solves this by making the intersection the starting point rather than an afterthought.

The Unified Control Architecture

The Nucleus Systems Cybersecurity Maturity Management Framework Version 1 (NS-CMMF v1.0) addresses framework proliferation by adopting a unified control architecture that begins at the intersection of all applicable frameworks, rather than building each framework in isolation. The design process began with a comprehensive mapping of all obligations across 32 frameworks and regulations, identifying unique security control obligations, eliminating duplicates, and resolving conflicts, before a single NS-CMMF control was defined.

The result is a control library of 270 re-engineered, modernized controls that together satisfy every significant obligation across all 32 mapped frameworks. Each control is explicitly mapped to every framework and regulation it satisfies, at the article and section level. This mapping is not decorative; it drives the framework filter on the Assessment Tool's Framework Report tab, enabling an assessor to see all controls relevant to any specific regulatory obligation immediately.

The Framework Intersection in Practice

To understand the power of the intersection-first approach, consider how NS-CMMF v1.0 handles the regulatory requirements for cybersecurity incident detection and logging. Across the 32 mapped frameworks, there are at least 8 distinct regulatory obligations related to security event logging:

Regulation / Framework	Specific Obligation	NS-CMMF Controls that Satisfy It
PCI DSS v4.0.1 Req. 10.2–10.5	Log collection for all system components; tamper-protected; 12-month retention	DE-01, DE-03, DE-05
DORA Art. 17	ICT-related incident event log for EU financial entities; structured classification	DE-01, DE-02, DE-10, DE-11
NIS2 Art. 21	Security monitoring capability enabling incident detection and classification	DE-01, DE-09, DE-10
SOX §802 / PCAOB AS 2201	Audit trail for financial systems; evidence of ITGC design and operating effectiveness	DE-01, DE-03, DE-22
HIPAA §164.312(b)	Audit controls for all systems containing ePHI, activity logs, and access records	DE-01, DE-05, DE-21
GDPR Art.32	Technical measures to ensure the confidentiality, integrity, and availability of processing	DE-01, DE-03, DE-21
ISO 27001 A.8.15	Logging of security events with defined retention and protection	DE-01, DE-03, DE-05
FedRAMP AU-2	Auditable events defined and logged; continuous monitoring for federal workloads	DE-01, DE-02, DE-04, DE-30

A conventional approach would require separate evidence collection and documentation for each of these eight obligations—potentially requiring the same SIEM configuration to be evidenced eight times for eight different audiences. NS-CMMF v1.0 collapses this into three controls (DE-01, DE-03, DE-05 at minimum) with a single evidence base that satisfies all eight obligations simultaneously. The framework filter on the Assessment Tool allows any auditor or regulatory examiner to immediately see the controls and evidence relevant to their specific obligation.

The 32-Framework Architecture: Design Decisions

The selection of 32 frameworks for the Nucleus Systems Cybersecurity Maturity Management Framework Version 1 (NS-CMMF v1.0) mapping was not arbitrary. Every framework included satisfies at least one of three criteria: regulatory materiality (it carries enforcement consequences that are material to the target market), technical specificity (it imposes specific technical or organizational measures that map to security controls), or sector relevance (it is mandatory or effectively mandatory for a significant segment of NS-CMMF's target market).

Structural Backbone ● NIST CSF 2.0 — universal framework providing the 6-domain structural architecture ● ISO/IEC 27001:2022 — most widely adopted certification standard globally ● CIS Controls v8 — implementation-level prescriptive control guidance ● COBIT 2019 — governance and management objectives for IT ● CMMI v2.0 — maturity model structure and level definitions AI & Emerging Tech ● NIST AI RMF 1.0 — AI risk management for organizations developing or deploying AI ● EU AI Act — legal obligations for high-risk AI systems in the EU ● ISO 42001 — AI management system standard ● OWASP LLM Top 10 — security risks specific to LLM applications ● NIST PQC (FIPS 203–205) — post-quantum cryptography migration standards	Regulatory Obligations ● GDPR — EU personal data protection regulation ● NIS2 Directive — EU network and information security requirements ● DORA — EU digital operational resilience for financial entities ● Cyber Resilience Act — EU software security requirements ● HIPAA — US healthcare data protection ● SOX — US financial reporting controls ● PCI DSS v4.0.1 — payment card industry security standard ● FedRAMP — US federal cloud security requirements ● CCPA — California consumer privacy law ● NERC CIP — North American energy sector requirements ● IEC 62443 — international OT/ICS security standard ● Executive Order 14028 — US software supply chain security
--	---

The Hidden Advantage: Regulatory Interaction Mapping

Beyond the efficiency of consolidated evidence, NS-CMMF v1.0 provides a capability that no single-framework approach can deliver: regulatory interaction mapping. When regulatory obligations interact, and they frequently do, a single-framework approach cannot identify where one regulation's requirements strengthen, substitute for, or conflict with another's.

Consider a concrete example at the intersection of DORA and NIS2 for an EU-based financial entity that is both an essential entity under NIS2 and in scope under DORA. Both regulations impose incident notification requirements, but with different timelines, different regulatory recipients, different threshold criteria, and different evidence requirements:

Under NIS2 Art. 23, the organization must send a 24-hour early warning to its national CSIRT, a 72-hour detailed notification, and a 1-month final report. Under DORA Art. 19, it must send an initial notification within 4 hours of classifying a major ICT incident, an intermediate report within 72 hours, and a final report within 1 month to its competent supervisory authority (EBA, EIOPA, or ESMA). The thresholds for what constitutes a 'reportable incident' differ between the two frameworks, meaning an incident may trigger DORA reporting without triggering NIS2, or vice versa.

NS-CMMF v1.0's controls RS-18 (NIS2 Three-Stage Notification Process) and RS-19 (DORA Major Incident Reporting Process) are separately defined and separately assessed, because they represent genuinely distinct obligations. But the Assessment Tool's Framework Report tab shows both controls simultaneously when filtered by 'EU Financial Entity' profile, and the Dashboard's Compliance Floor Indicators flag both as critical if either is absent. This interaction-aware design prevents the dangerous assumption that compliance with one automatically implies compliance with the other.

One Control Library. One Maturity Model. One Source of Truth.

The operational impact of NS-CMMF v1.0's unified control architecture is profound. Instead of managing 10 separate framework programs, 5 separate audit tracks, and 100+ duplicated controls with separate evidence bases, an organization operates from a single control library that:

1. Satisfies all applicable regulatory obligations from a unified evidence base — evidence is collected once and attributed to multiple frameworks simultaneously.
2. Identifies genuine gaps (controls that no single applicable framework explicitly requires but that represent material security risk) rather than framework-specific gaps.
3. Enables regulatory horizon scanning — when a new regulation is added (EU AI Act, CRA, a new national NIS2 transposition), the framework mapping shows immediately which existing NS-CMMF controls already address the new obligation, and which require enhancement.
4. Provides a stable foundation for continuous improvement. Because the control library is stable and unified, maturity trends are comparable across assessment cycles regardless of which regulatory frameworks are added or modified.

NS-CMMF v1.0 doesn't just map 32 frameworks—it harmonizes them at the operational level. For the first time, an organization can tell any regulator, auditor, or investor committee exactly which controls satisfy which obligations, and prove it with a single, structured evidence base.